IT Policy Governance

Effective Date:
April 10, 2026

Category:
Security

Scheduled Review:
April 2027

1. Authority

Executive Order 2016-06, Enterprise Information Technology Governance

2. Document Control

This policy replaces, in its entirety, IT Policy Governance, dated April 7, 2025.

3. Purpose

This Information Technology Policy (ITP) establishes the governance structure and lifecycle for IT Policies. It also establishes the policy for exceptions to published ITPs.

4. Scope

This policy applies to all offices, departments, boards, commissions, and councils under the Governor's jurisdiction and any other entity connecting to the Commonwealth Network (hereinafter referred to as "agencies").

5. Policy

For definitions of terms found within this document, refer to the *IT Policy Glossary*.

Executive Order 2016-06, Enterprise Information Technology Governance, assigns the Office of Administration, Information Technology (OA/IT) enterprise-wide governance responsibility for the planning, acquisition, and management of Information Technology (IT) resources, including the development and publication of IT policies, standards, procedures, and guidelines.

Management Directive 245.13, Strategic Direction for Information Technology Investments, establishes Information Technology Policies as the formal means by which OA/IT defines, communicates, and enforces enterprise IT requirements and expectations.

Agencies may establish their own policies that are more restrictive than an Enterprise IT policy but may not circumvent the controls or requirements described in Enterprise IT policies.

5.1 IT Policy Lifecycle

All IT policies shall be reviewed every year by the Subject Matter Experts (SMEs). The review shall occur within 12 months from the last IT policy publication date. It is the responsibility of the IT Policy Coordinator and SMEs to conduct the annual review of the IT policy. Reviews of individual policies may be performed more frequently if a need arises. All reviews are to be documented in the IT policy's revision table including reviews that result in no revisions to the policy.

5.2 IT Policy Governance Framework

5.2.1 Governance, Risk, and Compliance Team

The OA/IT Governance, Risk, and Compliance (GRC) Team is responsible for the governance of IT Policies and related documents. This includes the creation and revision of IT policies as well as ownership of the review and approval process.

5.2.2 Policy Review Committee

The Policy Review Committee (PRC) provides oversight and guidance regarding IT policies in support of IT supplies and services within the Commonwealth. The Policy Review Committee establishes formal structures, membership, decision rights, roles, and responsibilities. This Committee is established and maintained by OA/IT for the purpose of conducting business related to IT policies.

5.2.3 OA/IT Senior Leadership

The Commonwealth CIO, Chief Information Security Officer (CISO), GRC Head or a designee will review and provide final approval or disapproval of IT policies.

5.3 IT Policy Exceptions

While, adherence to ITPs is required in order to protect the Commonwealth's IT Resources and mitigate business and IT risks, there may be circumstances where an IT policy exception is needed for a specific period. In these instances, OA/IT has an IT Policy Exception process in place, which allows agencies to request an exception from the requirements of a specific ITP.

Agencies shall submit an IT Policy Exception request when they are not able to comply with the requirements of an ITP, or when advised as necessary by OA/IT Senior Leadership. Agencies requiring an IT Policy Exception shall review and adhere to the process detailed in *IT Policy Exception Procedure*.

6. Contact

Questions or comments may be directed via email to OA, IT Policy.

7. Exception from Policy

In the event an agency chooses to seek an exception from this policy, a request for a policy

exception shall be submitted via the enterprise IT policy exception process. Refer to the above sections for guidance.

8. Revision History

This chart contains a history of this publication's revisions. Redline documents outline the revisions and are available to Commonwealth users only during the drafting process.

Version	Date	Purpose of Revision
Original	01/06/2025	Base Document
Revision	02/24/2025	Added document control section Misc. grammatical updates and clarifications Removed reference to the "scenarios table" in the Exception Procedure
Revision	04/07/2025	Replaced domain owners with SMEs Removed lifecycle management components Added section regarding policy review committee Removed references to *IT Policy Governance Procedure* (rescinded)
Revision	04/10/2026	Removed third parties from the scope Changed annual review and PRC requirements to only apply to policies (not standards, procedures, guidelines, etc.) Expanded final review to OA/IT senior leadership to provide flexibility